

Helpwise — Production Readiness

ถ้าใช้งาน production จริง (ลูกค้าจ่ายเงิน) ต้องทำอะไรเพิ่ม · **MUST** = กันตายก่อนรับลูกค้า · **SOON** = ควรมีเร็ว · **LATER** = scale ที่หลัง

1. Tenant Isolation / RLS

MUST

ตอนนี้: app-enforced ผ่าน tenantPrisma · RLS scaffold แต่ไม่ active (BYPASSRLS)

- สร้าง DB role ใหม่ที่ไม่มี BYPASSRLS สำหรับ runtime
- FORCE RLS + policy ทุกตาราง tenant · เปิด RLS_ENABLED=true พร้อม migration
- DB-level cross-tenant test (ตั้ง GUC เป็น A แล้ว query B → 0 แถว) + load test
- ESLint rule ห้าม import base prisma ใน route (ปิด human error)

2. Async Queue — QStash vs BullMQ

SOON

ตอนนี้: QStash (push) เหมาะ serverless แล้ว — ไม่ใช่จุดอ่อน

- BullMQ ไม่ใช่ 'ดีกว่า' — ใช้ก็ต่อเมื่อย้าย off serverless ไป server เปิดตลอด
- ต้องเพิ่ม: dead-letter queue + alert เมื่อ job fail หมด retry
- job status tracking + monitor queue backlog / fail rate

3. Email

MUST

ตอนนี้: Postmark scaffold (ไม่มี SDK) · SendGrid = TODO

- wire provider จริง + verify domain: SPF / DKIM / DMARC (กันเข้า spam)
- bounce/complaint webhook → suppress อีเมลเสีย (กัน reputation พัง)
- inbound parse webhook wire จริง + verify signature

4. Auth (AuthN/AuthZ)

MUST

ตอนนี้: JWT httpOnly 8h · ไม่มี refresh/rotation · agent login ยัง TODO

- password hashing (argon2/bcrypt) + refresh token + rotation + revocation
- rate limit + brute-force protection บน login/magic-link
- MFA สำหรับ agent โดยเฉพาะ OWNER/ADMIN

5. Observability / Ops

MUST

ตอนนี้: console.error เป็นหลัก · health endpoint มี · audit log immutable

- structured logging (pino) + centralized + requestId/tenantId ทุก log
- error tracking (Sentry) + metrics dashboard (latency, queue depth, SLA breach)
- alerting (PagerDuty) — รู้ก่อนลูกค้าโทรมา

6. Database / Scaling

SOON

ตอนนี้: Supabase single DB + pgbouncer · index บางส่วน

- Backup + PITR + ข้อม restore จริง (backup ที่ restore ไม่ได้ = ไม่มี) [MUST]
- read replica สำหรับ reporting · zero-downtime migration (expand-contract)
- per-tenant data export + delete (GDPR erasure) [MUST]

7. Security Hardening

MUST

ตอนนี้: CSP unsafe-inline · headers · rate limit · npm audit report-only

- nonce-based CSP (ลบ unsafe-inline) · WAF/DDoS · secrets rotation
- dependency scanning แบบ block high · attachment AV scanning
- rate limit ต่อ endpoint/user · pen test

8. AI

SOON

ตอนนี้: tenant-scoped, no-tools, fail-closed (ดี) · demo ยังไม่มี DPA

- DPA กับ Anthropic + tenant consent (PDPA/GDPR) ก่อนส่ง data [MUST]
- PII redaction ก่อนส่งเข้า LLM · cost budget/quota ต่อ tenant
- output validation · model pinning · opt-out ต่อ tenant

9. Billing

SOON

ตอนนี้: idempotent webhook + sync DB + money เป็น Int (ดี)

- reconciliation job — sync เป็นระยะเพื่อ webhook หาย
- dunning + grace period + proration + trial · Stripe Tax
- monitor webhook failure + Stripe CLI test ใน CI

10. Testing / CI-CD

SOON

ตอนนี้: Vitest unit+integration บางส่วน · CI lint/type/test/build

- E2E (Playwright) ครอบคลุม critical flow + cross-tenant isolation test
- staging environment (ตอนนี้ test บน prod ตรงๆ เสี่ยง)
- migration test บน Postgres จริง · canary/rollback

11. Compliance / Legal

SOON

ตอนนี้: — (B2B enterprise บังคับก่อนเซ็นสัญญา)

- SOC 2 / ISO 27001 track
- GDPR/PDPA: DPA, data residency, erasure/export, sub-processor list
- data retention policy + Terms/Privacy

12. Tenant Lifecycle

LATER

ตอนนี้: — (scale ที่หลัง)

- provisioning/deprovisioning + offboarding (export+delete)
- custom domain per tenant · seat management · usage metering

ลำดับที่ควรทำก่อน (ถ้าเริ่มรับลูกค้าจริงพรงนี้)

สัปดาห์แรก — กันตาย

- Backup + PITR + ซ้อม restore
- Auth ครบ (password hash, refresh, rate limit, MFA)
- Error tracking (Sentry) + alert พื้นฐาน
- Email deliverability (SPF/DKIM/DMARC + bounce)

เดือนแรก — ให้เชื่อใจได้

- เปิด RLS active (หรือ ESLint ban base prisma)
- structured logging + metrics + dashboard
- staging + E2E isolation test
- billing reconciliation + AI DPA/consent

ก่อนขายองค์กรใหญ่ / Scale ที่หลัง

- SOC2 track + GDPR/PDPA · WAF/DDoS + pen test
- read replica · BullMQ (ถ้าย้าย off serverless) · sharding

หลักคิด: "โค้ดทำงานถูก = 40% ของ production · อีก 60% คือ รู้เมื่อมันพัง + กู้คืนได้ + ปลอดภัยพอให้องค์กรเชื่อใจ"
(observability + resilience + compliance)